PhysLIMS 正式環境部署檢查表：環境變數與金鑰備份

Oct 27, 2026 · @文全 許

用途與適用範圍

自 2026-10-27 起，`appsettings.Production.json` 不再含任何密碼、金鑰或連線字串，正式環境必須在部署前以環境變數注入，否則系統無法啟動或無法連線。此調整依 ISO 27001（A.8.12 資料外洩防護、A.8.24 密碼技術）與資通安全管理法辦理。

組態載入順序如下，後者覆寫前者：

1. `appsettings.json`（版控，不含機密）
2. `appsettings.Production.json`（版控，機密欄位皆為空值）
3. `claudesettings.json`（主機端手動放置、不入版控、不隨發佈輸出；選用）
4. 環境變數（建議做法，最高優先）

環境變數以雙底線 `__` 表示階層，例如 `JwtSettings:SecretKey` 對應 `JwtSettings__SecretKey`。

部署流程總覽

同一份發佈檔，地端與雲端只差在機密注入與 Migration 方式



部署流程 · 地端 IIS 與雲端 / 容器兩條路徑

兩條路徑共用發佈、簽章、備份與檢核；地端由應用程式集區帶入機密並在啟動時 Migration，雲端由平台注入機密並先以單一個體 Migration 再擴展。

部署步驟

一次部署分為五個階段：首次準備、建置發佈、備份、切換、驗證；失敗時依「回復」還原。以下以地端 IIS 為主，雲端與容器的差異標在各步驟末。

1. **首次準備（僅新主機）**
   a. 安裝 .NET 10 Hosting Bundle（發佈設定為 win-x64、非自包含，主機必須有執行階段）。
   b. 建立 IIS 站台與應用程式集區 `PhysLIMS.API`（.NET CLR 版本選「沒有 Managed 程式碼」）。

   c. 在應用程式目錄外建立金鑰資料夾，ACL 只給 `IIS AppPool\PhysLIMS.API` 與系統管理員。
   d. DBA 建立 SQL 帳號 `app_sgs_user`（讀寫）與 `deploy_sgs_user`（DDL）。
   e. 依「必要環境變數」與「地端與雲端部署情境」設定環境變數，含 `DataProtection__KeysPath`。
   f. 雲端 / 容器：改為準備持久化磁碟、上傳 PFX 至平台機密服務。專案目前沒有 Dockerfile，需另行撰寫。
2. **建置與發佈（建置機）**
   a. `dotnet publish Host/PhysLIMS.API -c Release -p:PublishProfile=FolderProfile`，輸出至 `bin\Release\net10.0\publish\`。
   b. 確認輸出目錄只有 `appsettings.json` 與 `appsettings.Production.json` 兩個組態檔。
   c. 模組外掛 DLL 以受信任的程式碼簽章憑證（`ModularSettings:TrustedThumbprint`）完成 Authenticode 簽章；未簽章或簽章不符的模組會被略過。
3. **備份（正式主機）**
   a. 資料庫完整備份（啟動時會自動執行 Migration，失敗時靠此還原）。
   b. 金鑰資料夾備份。
   c. 現行發佈目錄整份複製一份，作為回復版本。
4. **切換（正式主機，建議離峰時段）**
   a. 停止應用程式集區：`Stop-WebAppPool PhysLIMS.API`。
   b. 複製發佈檔並保留伺服器端資料夾：`robocopy <publish> <站台目錄> /MIR /XD keys plugins logs /XF claudesettings.json`。
   c. 新版模組 DLL 放入 `plugins\`。
   d. 啟動應用程式集區：`Start-WebAppPool PhysLIMS.API`。啟動依序執行：組態驗證 → Data Protection 初始化 → 資料庫 Migration → 權限與管理員種子資料 → 載入模組 → 選單種子資料。
   e. 雲端 / 容器：多個執行個體時設 `Database__AutoMigrate=false`，由單一個體或一次性工作先執行 Migration，再放大其他個體。
5. **驗證**：逐項完成「部署前後驗證」的部署後檢核。

回復：停止應用程式集區 → 還原上一版發佈目錄 → 若本次含不相容的 Migration，還原部署前的資料庫備份 → 啟動。金鑰資料夾不要回退或刪除，舊版程式可以直接使用新的金鑰環。

注意事項

最容易造成資料遺失的是發佈時一併刪掉金鑰，其次是未備份就執行自動 Migration。

風險	原因	做法
金鑰被刪除，加密個資無法解密	發佈設定 `DeleteExistingFiles=true`，直接發佈到站台目錄會清空 `keys\`、`plugins\`、`logs\`	`KeysPath` 移到站台目錄外；一律先發佈到本機，再以 robocopy 排除這些資料夾
資料庫結構被改且無法回退	`Database:AutoMigrate=true`，啟動即套用 Migration	每次部署前備份資料庫；多個執行個體只讓一個執行 Migration
開發機密進入正式主機	舊版發佈檔含 `appsettings.Development.json`	2026-10-27 起已排除於發佈輸出；主機上較早部署殘留的該檔需手動刪除
stdout 日誌持續增長	`web.config` 開啟 `stdoutLogEnabled`，寫入 `logs\stdout`	首次啟動確認無誤後關閉，或排定清理；日誌已遮罩個資，仍屬稽核資料，需限制存取
模組未載入	模組 DLL 未以受信任憑證簽章，啟動時略過	部署前確認簽章指紋與 `TrustedThumbprint` 一致
全體使用者被登出	更換 `JwtSettings__SecretKey`，或金鑰環遺失	離峰時段執行並事先公告
不能搬機	DPAPI 模式的金鑰只能在原主機解密	預計搬機或增加主機前，先在原主機切換為憑證模式
應用程式集區每日回收	系統以管理員權限啟動時，會把回收時間設為每日 04:00	避免在 04:00 執行批次或部署

必要環境變數

以下 3 個變數未設定時，系統在啟動階段即失敗（先例外、不提供服務），每次部署前都要確認。

已設定	環境變數	用途	格式要求	未設定的後果
[ ]	`ASPNETCORE_ENVIRONMENT`	指定載入 `appsettings.Production.json`	固定為 `Production`	預設即為 Production；誤設為 Development 會開啟詳細錯誤頁與 EF 敏感資料日誌
[ ]	`PersistentSettings__ConnectionStrings__DefaultConnection`	應用程式執行期資料庫連線（`app_sgs_user`）	SQL Server 連線字串，須含 `Encrypt=True`	啟動失敗（`[Required]` + ValidateOnStart）
[ ]	*`JwtSettings__SecretKey`*	簽署存取權杖（JWT）	高熵亂數，UTF-8 至少 32 位元組；不可與開發環境相同	啟動失敗；且更換後所有使用者需重新登入

依功能啟用情況而必要的變數：

已設定	環境變數	何時需要	未設定的後果
[]	`PersistentSettings__ConnectionStrings__MigrationConnection`	`Database:AutoMigrate=true`（目前為 true），以 `deploy_sgs_user` 執行 Migration	回退使用 DefaultConnection；應用帳號無 DDL 權限時 Migration 失敗。此帳號僅在啟動時套用 Migration 期間使用，執行期一律使用 DefaultConnection
[]	`SeedAdmin__Password`	僅首次部署、系統尚無 `sysadmin` 帳號時	略過建立管理員（角色仍初始化）。建立完成後應移除此變數
[]	`AlertSettings__Smtp__Password`	`AlertSettings:IsEnabled=true` 且需寄送告警信	告警信件寄送失敗；寄件地址仍為 `your-email@gmail.com` 佔位值，需一併覆寫
[]	`HmsSettings__SharedSecret`	啟用 HMS 外部金鑰管理服務時（目前主程式未註冊）	呼叫 HMS 前即拒絕，不會以預設金鑰簽章
[]	`PersistentSettings__MessageBroker__RabbitMQ__Username` / `__Password`	啟用 RabbitMQ 訊息佇列時	無法連線 Broker
[]	`PersistentSettings__ConnectionStrings__BackupConnection`	啟用資料庫備份排程時，以僅具 `db_backupoperator` 的 `backup_sgs_user` 連線	回退使用 MigrationConnection；部署帳號沒有備份權限，備份回 422 失敗，不會產生備份檔
[]	`Scheduler__SystemAccount__ClientSecret`	啟用排程（`Scheduler__Enabled=true`）時；金鑰在「系統帳號管理」建立 `physlims-scheduler` 時只顯示一次	啟用排程系統無法啟動（Scheduler 組態於啟動時驗證）
[]	`Scheduler__Enabled` / `Scheduler__ApiBaseAddress` / `Scheduler__SystemAccount__ClientId`	啟用排程時（非機密，由腳本參數 `-EnableScheduler -SchedulerApiBaseAddress -SchedulerClientId` 寫入）	Enabled 未設為 true 時不執行任何排程（預設關閉）；其餘缺漏時系統無法啟動

組態變數在 2026-10-27 前曾以明文寫在 `appsettings.Production.json`，設定時請使用輪替後的新值（見「機密輪替」）。

資料庫帳號權限

系統執行時一律以 `app_sgs_user` 存取資料庫，只有啟動時套用 Migration 的期間會暫時改用 `deploy_sgs_user`，套用完立即切回。DBA 請執行 `docs/sql/20261027_grant_least_privilege_accounts.sql` 一次完成授權；各項權限都對應到系統實際會做的操作。

帳號	權限	範圍	用途
`app_sgs_user`	`SELECT`、`INSERT`、`UPDATE`、`DELETE`	Schema `core`、`org`	所有執行期資料存取，含 Outbox、Token、稽核與系統日誌的批次寫入

帳號	權限	範圍	用途
`app_sgs_user`	`VIEW DEFINITION`	Schema `core`、`org`	資料庫結構檢視（ERD、結構匯出）讀取資料表與欄位說明
`app_sgs_user`	`GENERATE LEDGER DIGEST`、`VIEW LEDGER CONTENT`	資料庫	Ledger 防篡改完整性驗證
`deploy_sgs_user`	`db_ddladmin`、`db_datareader`、`db_datawriter`	資料庫	建立與修改 Schema、資料表、索引、檢視，與 Migration 內的資料移轉
`deploy_sgs_user`	`ENABLE LEDGER`	資料庫	建立 Ledger 資料表（系統日誌、安全日誌）
`app_sgs_user`	`SELECT`、`INSERT`、`UPDATE`、`DELETE`	Schema `hangfire`	排程作業佇列、狀態與分散式鎖（資料表由 deploy_sgs_user 於啟動時建立）
`backup_sgs_user`	`db_backupoperator`	資料庫	資料庫完整 / 差異備份與 RESTORE VERIFYONLY；登入帳號由 DBA 建立並自訂密碼
`backup_sgs_user`	`CREATE DATABASE`	master	備份後 RESTORE VERIFYONLY 驗證備份檔（db_backupoperator 不含此權限）；不使用 dbcreator。不允許時改設 `Scheduler__DatabaseBackup__Verify=false`

`app_sgs_user` 不授予 `CREATE TABLE`、`ALTER`、`db_ddladmin` 或 `db_owner`。若執行期出現權限不足的錯誤，表示有程式在執行期做 DDL，應修正程式，而不是放寬權限。Ledger 驗證需要的快照隔離（`ALLOW_SNAPSHOT_ISOLATION`）由 DBA 於腳本中一次開啟。後續新增模組若使用新的 Schema，需比照 `org` 補上授權。

啟用排程前，DBA 另需執行 `docs/sql/20261028_grant_scheduler_hangfire_backup.sql`：預先建立 `hangfire` Schema、授予 `app_sgs_user` DML，並把 `backup_sgs_user` 加入 `db_backupoperator`。腳本中建立登入帳號的段落是註解，需 DBA 自訂密碼後取消註解；備份目錄的寫入權限要給 SQL Server 服務帳號，而不是 `backup_sgs_user`。

選用環境變數

建議正式環境設定 `DataProtection__KeysPath`，把金鑰環移到應用程式目錄外，避免重新部署或清空發佈目錄時一併刪除。

環境變數	預設值	建議值
`DataProtection__KeysPath`	`<應用程式目錄>\keys`	應用程式目錄外的專用資料夾，例如 `D:\PhysLIMS\DataProtectionKeys`，僅 App Pool 帳號與系統管理員可讀寫
`Database__AutoMigrate`	`true`	若改由 DBA 執行 Migration 腳本，設為 `false` 後即不需 MigrationConnection

`PhysLIMS_LedgerEnabled` 由系統啟動時的 IIS 自動設定寫入，不需手動設定。

IIS 設定方式

由系統管理員在部署時執行 `deploy/Set-PhysLIMSAppPoolEnvironment.ps1`，自動寫入應用程式集區 `PhysLIMS.API` 的環境變數。腳本在程序內直接寫入 `applicationHost.config`（只有系統管理員可讀），機密不會出現在命令列、畫面或日誌中；不要把機密寫進發佈目錄的 `web.config`。

1. 以系統管理員身分開啟 Windows PowerShell 5.1（不是 PowerShell 7）。
2. 首次部署：`.\Set-PhysLIMSAppPoolEnvironment.ps1 -KeysPath 'D:\PhysLIMS\DataProtectionKeys' -OptionalSecrets MigrationConnection, SeedAdminPassword`。腳本會逐一要求輸入機密兩次（不顯示），驗證後寫入並回收應用程式集區。
3. 建立 `sysadmin` 後移除初始密碼：`.\Set-PhysLIMSAppPoolEnvironment.ps1 -Remove SeedAdmin__Password`。
4. 輪替機密：`.\Set-PhysLIMSAppPoolEnvironment.ps1 -Force -OnlySecrets JwtSecretKey`。
5. 啟用排程（Hangfire）：`.\Set-PhysLIMSAppPoolEnvironment.ps1 -EnableScheduler -SchedulerApiBaseAddress 'https://sgs-framework-api.shanda.site/' -SchedulerClientId 'physlims-scheduler' -OptionalSecrets BackupConnection, SchedulerClientSecret`。腳本會拒絕與 DefaultConnection 或 MigrationConnection 共用帳號的 BackupConnection，並在缺少系統帳號設定時停止。
6. 只想預覽變更時加上 `-WhatIf`；若已安裝 SecretManagement 模組，可用 `-VaultName` 從保管庫讀取機密（名稱為 `PhysLIMS-<環境變數名稱>`），免互動輸入。

腳本寫入前會拒絕不安全的值：連線字串缺 `Encrypt=True`、JWT 金鑰不足 32 位元組、DefaultConnection 與 MigrationConnection 使用同一個 SQL 帳號。集區已有的機密預設保留，可重複執行；結束時只列出變數名稱與動作，並提醒尚未設定的必要變數。若無法使用環境變數，可改放 `claudesettings.json` 於發佈目錄（格式見 `claudesettings.example.json`），並把檔案權限限縮為 App Pool 帳號與系統管理員。

地端與雲端部署情境

同一份程式依執行環境自動選擇金鑰保護方式（`DataProtection__Mode=Auto`，預設值），不需要為地端或雲端分別建置。無法確保金鑰「加密存放」且「持久保存」時，正式環境會拒絕啟動，而不是在不安全的狀態下運作。

部署情境	自動選擇	需額外設定	機密注入方式
地端單一 Windows + IIS	DPAPI	無	IIS 應用程式集區環境變數
地端多台 / 災備主機	憑證	每台安裝同一張憑證，設 `DataProtection__Certificate__Thumbprint`；`KeysPath` 指向共用資料夾（SMB）	IIS 應用程式集區環境變數
雲端 Windows VM	DPAPI（單台）或憑證（多台）	同地端	VM 環境變數或 IIS 應用程式集區
Azure App Service（Windows）	憑證	上傳憑證並設 `WEBSITE_LOAD_CERTIFICATES=<指紋>`；`Thumbprint` + `StoreLocation=CurrentUser`	App Settings（可引用 Key Vault）
容器（Docker / Kubernetes / Linux）	憑證（未設定則拒絕啟動）	PFX 以 Secret 掛載，設 `PfxPath` + `PfxPassword`；`KeysPath` 必填，指向持久化磁碟（Azure Files、EFS、PVC）	Kubernetes Secret 或平台機密服務轉為環境變數

應用程式在非 Windows 主機或容器中會自動略過 IIS 應用程式集區設定。Windows 整合驗證在無 AD 的雲端環境不可用，需以 JWT 登入。

憑證相關環境變數：

環境變數	說明
`DataProtection__Mode`	`Auto`（預設）、`Dpapi`、`Certificate`；`None` 僅限開發環境
`DataProtection__Certificate__Thumbprint`	Windows 憑證存放區 `My` 中的憑證指紋，需含私密金鑰

環境變數	說明
`DataProtection__Certificate__StoreLocation`	`LocalMachine`（預設）或 `CurrentUser`
`DataProtection__Certificate__PfxPath` / `__PfxPassword`	容器使用；PFX 密碼為機密
`DataProtection__Certificate__PreviousThumbprints__0`	憑證輪替時填入舊憑證指紋，舊金鑰才能繼續解密

從 DPAPI 改為憑證時，請在原主機上先切換並啟動一次。新金鑰會改以憑證加密，舊的 DPAPI 金鑰仍只能在原主機解密，在舊金鑰到期（預設 90 天）且其加密的資料重新儲存前，不要將服務遷出原主機。

Data Protection 金鑰備份與還原

Data Protection 金鑰環同時保護登入 Cookie 與「落地加密」的個資欄位（目前為使用者電話 `PhoneNumber`），金鑰遺失即表示這些個資永久無法解密。DPAPI 模式的備份**只能在原主機上解密**；憑證模式的備份可在任何安裝同一張憑證的主機還原，但憑證（PFX）必須另行備份。

備份：

- [ ] 將金鑰資料夾（`DataProtection__KeysPath`，未設定則為 `<應用程式目錄>\keys`）全部 `key-*.xml` 納入每日備份。
- [ ] 備份留存期間不短於資料庫備份；舊金鑰不可刪除，它們仍用於解密較早寫入的資料。
- [ ] 備份位置存取權限限縮為系統管理員，且與資料庫備份分開存放。
- [ ] 2026-10-27 前建立的金鑰檔為未加密明文，在其 `expirationDate` 到期前仍是預設金鑰；請確認資料夾 ACL 只有 App Pool 帳號與系統管理員可讀。
- [ ] 憑證模式：PFX 與其密碼分開存放於密碼管理工具或金鑰保管庫，憑證到期前安排輪替（舊指紋填入 `PreviousThumbprints`）。

還原：

- [ ] 原主機重新部署：把 `key-*.xml` 放回金鑰資料夾後重啟應用程式集區。
- [ ] 確認可正常讀取一筆已加密使用者的電話（資料庫中為 `enc:v1:` 開頭），而非出現解密錯誤。
- [ ] 換主機或多台伺服器共用：DPAPI 備份無法使用，需使用憑證模式（見「地端與雲端部署情境」），並在新主機安裝同一張憑證。

機密輪替

下列機密曾以明文寫在版控或發佈檔中，從檔案移除並不會讓舊值失效，全部需要更換。

完成	機密	曾出現位置	輪替方式
[ ]	SQL 帳號 `app_sgs_user` 密碼	`appsettings.Production.json`、`appsettings.Development.json`	DBA 更改密碼後更新 DefaultConnection
[ ]	SQL 帳號 `deploy_sgs_user` 密碼	同上	DBA 更改密碼後更新 MigrationConnection
[ ]	JWT SecretKey	`appsettings.Production.json`	產生新亂數；更換後全體使用者需重新登入，建議於離峰時段執行
[ ]	`sysadmin` 初始密碼	`appsettings.Production.json`	登入後由系統管理員自行更改密碼
[ ]	BaGet NuGet API Key	5 個 `.csproj`	於 BaGet 伺服器更換，新值以環境變數 `BaGetApiKey` 提供給打包機
[ ]	本機 NuGet API Key	8 個 `.csproj`	同上，環境變數 `LocalNuGetApiKey`

產生 JWT 金鑰範例（PowerShell）：`[Convert]::ToBase64String([Security.Cryptography.RandomNumberGenerator]::GetBytes(48))`，產生 64 字元。

部署前後驗證

部署前：

- [ ] 必要環境變數 3 項皆已在 App Pool 設定，且為輪替後的新值。
- [ ] 發佈目錄中沒有 `appsettings.Development.json` 與開發機的 `claudesettings.json`。
- [ ] 金鑰資料夾已備份，且不在會被發佈覆蓋的目錄內。
- [ ] 資料庫完整備份已完成，且確認可還原。
- [ ] 現行發佈目錄已複製為回復版本。
- [ ] 模組 DLL 皆已以 `TrustedThumbprint` 對應的憑證簽章。
- [ ] 已公告停機時段（若本次更換 JWT 金鑰，需告知全體使用者將重新登入）。
- [ ] DBA 已執行「資料庫帳號權限」的授權腳本，且驗證查詢顯示 `app_sgs_user` 沒有 `CREATE TABLE` 或 `ALTER`。

- [ ] 啟用排程時：DBA 已執行 `20261028_grant_scheduler_hangfire_backup.sql`，以 `app_sgs_user` 查詢 `fn_my_permissions('hangfire','SCHEMA')` 列出四種權限，且 `backup_sgs_user` 的 `IS_ROLEMEMBER('db_backupoperator')` 為 1。
- [ ] 啟用排程時：已在「系統帳號管理」建立 `physlims-scheduler`，授予 `database.backup`、`accessreview.campaign.schedule`、logs.cleanup（新增作業時記得補授對應 Scope），金鑰已存入保管庫或直接交給執行腳本的管理員。

切換中：

- [ ] 複製時已排除 `keys`、`plugins`、`logs` 與 `claudesettings.json`。
- [ ] 站台目錄中沒有殘留的 `appsettings.Development.json`。
- [ ] 啟動後 5 分鐘內無 Migration 失敗或組態驗證失敗的錯誤日誌。

部署後：

- [ ] 應用程式啟動成功，日誌中無 `SecretKey 不得為空` 或 `DefaultConnection` 驗證失敗。
- [ ] 新產生的 `key-*.xml` 內容為 `encryptedSecret`（DPAPI）或 EncryptedXml（憑證），而非明文 `masterKey`。
- [ ] 以測試帳號修改電話後，資料庫 `PhoneNumber` 欄位為 `enc:v1:` 開頭，系統畫面顯示正常。
- [ ] 稽核紀錄（AuditLogs）中該筆修改的電話值為遮罩，而非明文。
- [ ] 系統日誌中的手機號碼、連線字串密碼與 Bearer Token 皆已遮罩。
- [ ] 首次部署建立 `sysadmin` 後，移除 `SeedAdmin__Password` 並回收應用程式集區。
- [ ] 啟用排程時：啟動日誌出現三行 `[Scheduler] 已註冊週期作業` 或「未啟用」，沒有「註冊週期作業...失敗」；`GET api/v1/scheduler/jobs` 的已啟用作業 registered 為 true。
- [ ] 啟用排程時：以 `POST api/v1/scheduler/jobs/database-backup-full/trigger` 觸發一次完整備份，作業狀態為 Succeeded，備份目錄出現 `PhysLIMSDB_FULL_*.bak`，日誌顯示「驗證：True」。

回復（部署後檢核未通過時）：

- [ ] 已停止應用程式集區並還原上一版發佈目錄。
- [ ] 本次含不相容 Migration 時，已還原部署前的資料庫備份。
- [ ] 金鑰資料夾未被回退或刪除。
- [ ] 回復後重新執行部署後檢核，並記錄失敗原因。

啟動日誌會記錄一行 `Data Protection 金鑰保護：<模式>（<原因>），金鑰路徑：<路徑>`，部署後請確認模式與路徑符合上表的部署情境。